AmasPortal 相依套件安全檢查報告

專案：AmasPortal（repo 資料夾名稱）
檢核日期：2026/11/12
檢查工具：Yarn Audit（Yarn Classic 1.22.22， `yarn audit --json`）
專案 Node.js： `.nvmrc` =18、 `package.json` 的 `engines.node` = >=18 <20 、CI（ `frontend-lint.yml`）讀取 `.nvmrc`
整理工具： `parse_audit.py` + `semver_helper.js` （semver 7.7.2），版本清單來自 npm registry，交叉確認來自 OSV

一、本次掃描結果

yarn audit 摘要（取自 `auditSummary`）：203 vulnerabilities，Packages audited 577。

1-1 漏洞嚴重程度

Severity	漏洞筆數
High	117
Moderate	78
Low	8
Info / Critical	0
合計	203

說明：筆數是 yarn audit 的記錄筆數，不等於不同套件數。同一個套件可能有多個漏洞，也可能透過不同依賴路徑重複出現。另有 33 筆 Advisory 的 CVSS 分數為 0，代表尚未評分，不是沒有風險，本報告以 severity 標籤判讀。

1-2 本專案處理狀況

處理分類	數量	意義
A：需要優先處理	0	確認符合優先處理條件
B：建議修復	39	已有修復建議
C：目前影響有限	40	有證據支持目前可暫緩
D：需要更多資訊	27	尚有關鍵條件待確認
合計	106	唯一 Advisory 數

- Severity 是漏洞本身的嚴重程度；A–D 是依本專案影響與證據所做的處理分類。
- 兩者統計單位不同（記錄筆數 vs 唯一 Advisory），不要把 1-1 的 203 與 1-2 的 106 混為一談。

判斷 A–D 時會用到的 Reachability

Reachability（程式碼可達性）是指專案是否有機會執行到漏洞所在的程式碼。

- Reachable：已找到執行路徑。
- Unreachable：有足夠證據確認不會執行。
- Unknown：目前資料不足，無法確認。

「搜尋不到」不等於 Unreachable，需要正面證據；證據與分析見第四章。

1-3 本次處理結論

本次沒有確認需要立即處理的 A 類項目，但仍有 39 筆建議修復、27 筆需要補充資訊。正式更新時，應優先處理第二章列出的直接依賴更新動作；其餘項目依目前證據暫緩或持續追蹤。

1-4 本次計數

先認識三個名詞

1. 直接依賴：你在專案 `package.json` 裡安裝的套件，通常是工程師安排更新時的入口。
2. 弱點套件：真正被安全公告指出有漏洞的套件，可能是直接安裝，也可能是其他套件間接帶進來的。
3. Advisory：描述某項弱點的安全公告。同一個套件、同一個版本，可能同時受到多筆 Advisory 影響。

開發者能動手的只有直接依賴，所以第二章的更新清單以直接依賴為單位，漏洞再回頭對應到弱點套件與 Advisory。

統計結果

統計項目	數量	說明
原始記錄筆數	203	Yarn Audit 回報的漏洞記錄總數；同一則公告經由不同依賴路徑會重複列出（原因見下方）
唯一 Advisory	106	把重複的記錄合併後，實際只有 106 則不同的安全公告；後續分類與更新都以這個數字計算
唯一 CVE	87	這些公告中，總共有 87 個不同的 CVE 編號（與 Advisory 的對應見下方）
唯一弱點套件	26	有漏洞的套件名稱，共 26 種
直接依賴	17	專案直接安裝的套件中，有 17 個引入了弱點套件（更新的修復單位）
直接依賴 × 弱點套件	44	17 個直接依賴與 26 種弱點套件之間，實際存在 44 組引入關係；只用來檢查依賴路徑是否整理完整，不是 Advisory 數

CVE 與 Advisory 的對應

- 106 筆唯一 Advisory 中，101 筆具有 CVE 編號，另外 5 筆只有 GHSA 編號。
- 101 筆具有 CVE 編號的 Advisory 中，有 28 筆涉及 14 個重複的 CVE 編號（每個重複的 CVE 各對應 2 筆 Advisory）。
- 因此，唯一 Advisory 數量為 101 + 5 = 106 筆；唯一 CVE 數量為 101 - 14 = 87 個（注意是減去重複的 CVE 數 14，不是減去涉及的 Advisory 筆數 28）。
- 這表示 Advisory 與 CVE 並非一對一關係，同一個 CVE 可能出現在多筆 Advisory 中。

為什麼原始記錄會重複（203 → 106）

Yarn Audit 檢查後，發現同一項漏洞可能透過不同依賴路徑出現。例如：

```
專案
├── vite-plugin-checker
│   └── picomatch 4.0.3
│       └── Advisory 1115551
│
└── neostandard
    └── …（多層依賴）
        └── picomatch 4.0.3
            └── Advisory 1115551
```

- 原始記錄會出現多次（每條路徑一筆；Advisory 1115551 實際有 7 條路徑，列了 7 筆）。
- 但實際上是同一個弱點套件版本（picomatch 4.0.3）。
- Advisory 1115551 仍然只有一則不同的安全公告。

所以 203 是原始記錄筆數，106 是合併重複後的唯一 Advisory 數。

1-5 資料交叉確認（OSV）

OSV 是什麼？為什麼要交叉確認？

- OSV（Open Source Vulnerabilities）是公開的開源漏洞資料庫，可以用「套件＋版本」直接查詢該版本有哪些已知漏洞。
- yarn audit 的結果來自單一資料來源，可能漏列、或更新較慢；另外，本報告的「建議修復版本」是腳本用版本範圍算出來的，不能保證該版本真的已經沒有漏洞。

- 所以另用 OSV 做第二個來源，檢查兩件事：
  1. 目前安裝的版本：OSV 與 yarn audit 的結果是否一致，有沒有 OSV 才查得到的漏洞。
  2. 建議修復版本：更新後的版本在 OSV 是否查得到其他漏洞。查詢結果為空，才標記為「已驗證」。

「已驗證」代表在本次查詢時間點，OSV 沒有回報該套件版本的已知漏洞；不代表該版本絕對沒有安全問題。

查詢範圍（兩種查詢分開計算）

- 已安裝版本核對：30 組（弱點套件，已安裝版本），即 3-2 表的全部列。
- 修復候選版本核對：另外針對 3-2 表的「目標版本」查詢，不包含在上述 30 組內。其中 23 列標為「已驗證」；其餘 7 列（跨 Major、超出上層範圍、部分修復或暫緩）的查詢說明見 3-2 各列備註。被 OSV 否決而改用其他版本的候選，列在下方。

核對結果

本節的 OSV 查詢於 2026/11/12 重新執行：已安裝版本 30 組與目標版本 29 組的結果，與前一次（2026/11/11）完全一致； `yarn.lock` 與 audit 輸出（203 筆記錄、106 則唯一 Advisory，Advisory ID 逐筆比對一致）皆無變動。

已安裝版本核對（30 組）：

- OSV 與 yarn audit 一致，只有 sweetalert2 11.22.3 多出 4 筆 OSV 獨有的 LOW（皆為「hidden functionality」類，GHSA-457r-cqc8-9vj9、GHSA-8jh9-wqpf-q52c、GHSA-pg98-6v7f-2xfv、GHSA-qq6h-5g6j-q3cm）；升到 11.22.4 後 OSV 查詢為空。

修復候選版本核對：

- **腳本候選版本被 OSV 否決 2 組**：follow-redirects 1.16.0 仍受 3 筆 High 影響（OSV 獨有，修補版 1.16.2）；lodash / lodash-es 4.18.0 仍受 GHSA-f23m-r3pf-42rh 影響（修補版 4.18.1）。本報告已改用 1.16.2、4.18.1。
- 其餘候選版本的 OSV 版本查詢皆為空。

二、建議處理事項

2-1 處理分類（A → D → B → C）

每個分類只呈現數量、代表項目、判斷原因、下一步。完整依據在第四章與附錄 B。

A：需要優先處理（0 筆）

- 沒有任何一筆同時滿足「可達已確認、攻擊者能控制輸入、存在可利用的執行環境、影響正式服務或部署產物」。
- 最接近的是 axios 原型污染 gadget（案例 1），但缺少「別處已有污染來源」這個前提，所以歸 D。這是逐筆分析的結果，不是預設值。
- 下一步：無。若 D 的待確認項目查證後成立，再升為 A。

D：需要更多資訊（27 筆；Runtime 排在前）

表 2-1-1　需要更多資訊（D）項目

項目	Advisory 數	還缺什麼（只寫待確認條件）	下一步（只寫具體行動）
axios 原型污染 gadget（Runtime）	12	第三方套件是否存在可由外部輸入觸發的原型污染來源	檢查 i18n-js 的 `merge` 、tablesorter、jQuery 外掛處理外部輸入的路徑，或直接更新 axios 1.20.0
vite（開發伺服器）	8	開發機是否使用 Windows / launch-editor；是否有符合條件的 .map 檔；import 路徑是否符合條件	詢問團隊、檢查 .map 與 import 路徑，或評估升級 vite 6.4.5
sweetalert2	1	部署網域的 TLD（公告：特定 TLD 才觸發）	確認部署網域，或升級 11.22.4
nanoid、source-map-js、postcss（1117015）、@humanfs/node	6	呼叫者傳入的參數或功能是否被使用	檢查 postcss、vue compiler-sfc 呼叫 nanoid 與 source-map 的參數；確認 eslint 是否呼叫 humanfs 的遞迴複製

Advisory ID 見附錄 B。

B：建議修復（39 筆）

表 2-1-2　建議修復（B）項目

弱點套件	Advisory 數	判斷原因
axios	3	mergeConfig 的 __proto__ key：每次請求都會走到；5 處呼叫的設定皆為程式內的物件常值，不是 JSON.parse 的外部物件
brace-expansion	14	工具鏈（eslint、neostandard、tailwindcss）做檔案比對時使用；pattern 來自設定檔或 repo，非外部輸入
browserslist	1	autoprefixer 每次建置都會查詢；查詢條件為專案設定，非外部輸入；長時間執行的 dev server 才會累積
immutable	3	sass 編譯期使用；輸入為 repo 內 scss，非外部輸入
minimatch	7	工具鏈（eslint、neostandard、tailwindcss）做檔案比對時使用；pattern 來自設定檔或 repo，非外部輸入
picomatch	4	工具鏈（eslint-plugin-tailwindcss、lint-staged、neostandard、tailwindcss、vite-plugin-checker）做檔案比對時使用；pattern 來自設定檔或 repo，非外部輸入
postcss	3	建置時對專案 CSS 與相依套件 CSS 執行；sourceMappingURL 來自 repo 內檔案或相依套件，非外部輸入
postcss-selector-parser	2	tailwindcss / eslint-plugin-vue 建置與 lint 時解析專案內的 selector；輸入為 repo 檔案
rollup	1	vite build 的打包輸出；輸出檔名由專案設定與外掛決定，非外部輸入
vite	1	Procfile.dev 以 bin/vite dev 啟動，config/vite.json 設定 host 0.0.0.0、port 3056，dev server 對區網開放；appType 為預設 spa，符合公告前提（對外開放＋spa / mpa）。影響開發機，不影響正式環境

B 不代表低風險。「實際要更新哪個套件、到哪個版本」見 2-2。

C：目前影響有限，可暫緩（40 筆）

每筆 C 的依據在附錄 B 逐筆列出。

表 2-1-3　目前影響有限（C）項目

群組	判斷原因	重新評估時機
axios Node / fetch 專屬、follow-redirects、form-data（19 筆）	專案只在瀏覽器使用 axios，Node http adapter 不會執行（browser 欄位、`myAxios.js` 、打包產物搜尋）	專案開始指定 `adapter` 、使用 `params` / `paramsSerializer` 、傳 `FormData` ，或 axios 被用於 Node 端（SSR、腳本）
lodash、lodash-es	使用者的原始碼沒有呼叫弱點函式（見案例 6）	專案使用 `Form.useForm` / `a-form` ，或升級 ant-design-vue / i18n-js 後其原始碼改呼叫弱點函式
@hotwired/turbo	專案沒有 turbo-frame，只用 Turbo Drive	專案開始使用 `<turbo-frame>`
@vue/server-renderer	專案沒有 SSR	專案導入 SSR
esbuild、glob、ajv、js-yaml、yaml、flatted、browserslist（stats）	觸發前提不成立，逐筆見附錄 B	新增 YAML 設定、使用 `--cache` 、使用 browserslist 統計檔、執行 glob CLI，或 vite 改用 esbuild 的 serve API
vite dev server（1107323、1242724）	公告前提不成立（public 無 symlink、appType 為預設）	public 目錄加入 symlink，或改用 appType custom / middlewareMode

2-2 建議更新動作（工程師的執行清單，依直接依賴，已去重）

本表是實際更新工作的主要清單。2-1 的 B 回答「為什麼要修」，本表回答「更新哪個直接依賴、到哪個版本」。專案沒有 `resolutions` 欄位；傳遞依賴若超出上層宣告範圍，需升直接依賴或新增 `resolutions` （工程師決策）。

表 2-2-1　建議更新動作

順位	直接依賴	目前版本	建議版本	更新幅度	涉及 Advisory 數（依 A–D 分類）	預期消除的 Advi
1	axios	1.11.0	1.20.0（連帶 follow-redirects 1.16.2、form-data 4.0.6）	Minor	34（B 3 / C 19 / D 12；組成見表 2-2-2）	34
2	sweetalert2	11.22.3	11.22.4	Patch	1（D 1）	1
3	vue / postcss（鎖檔更新）	vue 3.5.18、postcss 8.5.6	vue ≥3.5.42、postcss 8.5.23（連帶 nanoid 3.3.18、source-map-js 1.2.2）	Patch / Minor	9（B 3 / C 1 / D 5；組成見表 2-2-3）	8（另 1 筆待決）
4	工具鏈鎖檔更新（eslint、neostandard、tailwindcss、lint-staged、eslint-plugin-*、sass、autoprefixer、vite-plugin-checker）	見 3-2	brace-expansion 1.1.21 / 2.1.7、minimatch 3.1.4、picomatch 2.3.2 / 4.0.4、immutable 5.1.8、browserslist 4.28.7 等	Patch	41（B 26 / C 14 / D 1；組成見表 2-2-5）	41
5	vite	5.4.19	6.4.5（rollup 另需鎖檔更新至 ≥4.59.0）	Major（5→6）	13（B 2 / C 3 / D 8；組成見表 2-2-4）	1（另 12 筆待決）
6	@tailwindcss/typography	postcss-selector-parser 6.0.10（被精確釘住）	6.1.5	需進一步確認	1（B 1）	0（另 1 筆待決）

順位	直接依賴	目前版本	建議版本	更新幅度	涉及 Advisory 數（依 A–D 分類）	預期消除的 Advi
7	minimatch 9.x 線（eslint、neostandard、tailwindcss）	9.0.5	9.0.9（不要選 9.0.6–9.0.8）	Patch	3（B 3）	3
8	@hotwired/turbo	7.3.0	8.0.21	Major（7→8，暫緩）	1（C 1）	0（另 1 筆暫緩）

- 本表涵蓋 103 筆（B 38 / C 38 / D 27）。其餘 3 筆（B 1：1244623；C 2：glob 的 1109842、1244013）受 Node 18 限制或無法單獨更新，不在本表，見 2-3。兩者合計 106 筆，與 1-2 相符。
- 「涉及 Advisory 數」是這個更新動作牽涉的唯一 Advisory（去重後），包含 B、C、D，不代表全部都需要修復。例如 axios 的 34 筆中，B 只有 3 筆，其餘是 C、D。
- 「預期消除的 Advisory（已驗證）」是目標版本已通過 OSV 核對、更新後預期會消失的數量；尚未驗證、需跨 Major 或超出上層範圍的列為「待決」。
- 由多個弱點套件加總的列，組成見下方表 2-2-2 至表 2-2-5（各表合計等於表 2-2-1 的「涉及」數字）。

表 2-2-2　axios 的 Advisory 組成（34 筆）

弱點套件	Advisory 數	B	C	D
axios	32	3	17	12
follow-redirects	1	0	1	0
form-data	1	0	1	0
合計	34	3	19	12

表 2-2-3　vue / postcss 的 Advisory 組成（9 筆）

弱點套件	Advisory 數	B	C	D
postcss	4	3	0	1
nanoid	3	0	0	3
source-map-js	1	0	0	1
@vue/server-renderer	1	0	1	0
合計	9	3	1	5

表 2-2-4　vite 的 Advisory 組成（13 筆）

弱點套件	Advisory 數	B	C	D
vite	11	1	2	8
esbuild	1	0	1	0
rollup	1	1	0	0
合計	13	2	3	8

表 2-2-5　工具鏈鎖檔更新的 Advisory 組成（41 筆）

弱點套件	Advisory 數	B	C	D
brace-expansion 1.x	7	7	0	0
brace-expansion 2.x	7	7	0	0
minimatch 3.x	3	3	0	0
picomatch 2.x	2	2	0	0
picomatch 4.x	2	2	0	0
immutable	3	3	0	0
browserslist	2	1	1	0
postcss-selector-parser	1	1	0	0
ajv	1	0	1	0
flatted	2	0	2	0
js-yaml	5	0	5	0
yaml	1	0	1	0
@humanfs/node	1	0	0	1
lodash	2	0	2	0
lodash-es	2	0	2	0
合計	41	26	14	1

vite 抉擇

- 留在 vite 5 最高只能到 5.4.21，OSV 仍有 8 筆，同版本線無解。
- 升 vite 6.4.5（`package.json` 的 `^5.0.0` 需改為 `^6`）可消除 vite 與 esbuild 的相關 Advisory；rollup 需另外把鎖檔更新到 ≥4.59.0，因為 vite 6.4.5 的 rollup 範圍 `^4.34.9` 已被目前的 4.46.2 滿足，不會自動更新。
- Node 18 符合；外掛相容（`@vitejs/plugin-vue` 5.2.4 peer `^5.0.0 || ^6.0.0`、`vite-plugin-ruby` 5.1.1 peer `>=5.0.0`、`vite-plugin-checker` 0.10.0 peer `>=2.0.0`）。
- 這些弱點只影響開發機與建置機，但 Major 升級需要整合測試（Rails 的 vite-plugin-ruby 設定、Sass 與 Tailwind 的建置輸出、E2E）。
- 建議排在 axios 與工具鏈更新之後，由工程師決定時程。

2-3 本次更新範圍以外的項目與後續追蹤

本表只列「這次更新不會消除」的 Advisory，共 18 筆（整體 106 筆減去表 2-2-1 預期消除的 88 筆）。C、D 的判斷原因與重新評估時機見 2-1，不在此重複。

項目	Advisory 數（分類）	本次不處理的原因	後續追蹤
vite（含 esbuild）	12（B 1 / C 3 / D 8）	跨 Major（5→6），需整合測試後再決定（見 2-2「vite 抉擇」）	排在 axios 與工具鏈更新之後，由工程師決定時程
@vue/server-renderer 3.5.18	1（C 1）	被 vue 精確釘住，超出上層範圍	vue 更新到 ≥3.5.42 後，用更新後的 yarn audit 確認
@tailwindcss/typography 的 postcss-selector-parser 6.0.10	1（B 1）	被 @tailwindcss/typography 精確釘住，超出上層範圍	確認 typography 新版是否放寬；否則加 `resolutions`（工程師決策）

項目	Advisory 數（分類）	本次不處理的原因	後續追蹤
@hotwired/turbo 7.3.0	1（C 1）	7.x 無修補版，需 Major（7→8）	日後升 Turbo 8；專案開始使用 turbo-frame 時立即重評
glob 10.4.5	2（C 2）	CLI 那筆暫緩（C）；AbortSignal 那筆需 14.0.2（跨 Major，依賴 minimatch ^11，受 Node 18 限制）	tailwindcss 更新 sucrase 或不再依賴 glob 時；專案 Node 提高到 20 以上時一併評估
minimatch 9.x 線的 1244623（Moderate）	1（B 1）	需 minimatch 11.0.1，它依賴 brace-expansion ^5.0.12（需 Node 20 以上），受專案 `engines.node <20` 限制（見 5-1）	專案 Node 調整到 20 以上時，一併升 minimatch 11.0.1

三、套件與漏洞明細

本章從兩個方向整理相同的依賴關係：

- 3-1 從專案安裝的套件往下查：哪些直接依賴帶進了有漏洞的套件？工程師應該從哪裡更新？
- 3-2 從有漏洞的套件往上查：這個漏洞套件是誰帶進來的？目前版本是多少？可以更新到哪個版本？

兩節是同一份依賴關係的不同視角，不代表兩批不同的漏洞。整體有多少筆不同的 Advisory，以 1-4 為準。

3-1 依直接依賴整理（更新入口）

從專案直接安裝的套件出發，整理它所引入的弱點套件。主要用來確認工程師應該更新哪些直接依賴。

筆數提醒：本表依直接依賴分組，同一則 Advisory 若經由多個直接依賴引入，會在不同列重複計算（本次有 28 則 Advisory 出現在不只一個直接依賴底下）。本次各列 Advisory 數加總為 145 筆，並非整體唯一 Advisory 數；整體數字以 1-4 的 106 筆為準。

「修復狀態」：預期消除只計目標版本已驗證的項目；需跨 Major、超出上層範圍、受 Node 限制或暫不處理的列為待決。Advisory ID 不放在本表，完整追溯見附錄 B。

直接依賴	package.json 類型	執行情境	弱點套件@版本	代表依賴路徑（每個弱點套件列一條最短路徑）
@hotwired/turbo	dependencies	Runtime	@hotwired/turbo@7.3.0	@hotwired/turbo
@tailwindcss/typography	devDependencies	Build-time	postcss-selector-parser@6.0.10	@tailwindcss/typography > postcss-selector-parser
ant-design-vue	dependencies	Runtime	lodash@4.17.21, lodash-es@4.17.21	ant-design-vue > lodash ant-design-vue > lodash-es
autoprefixer	devDependencies	Build-time	browserslist@4.25.2	autoprefixer > browserslist
axios	dependencies	Runtime	axios@1.11.0, follow-redirects@1.15.11, form-data@4.0.4	axios axios > follow-redirects axios > form-data
eslint	devDependencies	Development-time	@humanfs/node@0.16.6, ajv@6.12.6, brace-expansion@1.1.12, flatted@3.3.3, js-yaml@4.1.0, minimatch@3.1.2	eslint > @humanfs/node eslint > ajv eslint > minimatch > brace-expansion eslint > file-entry-cache > flat-cache > flatted eslint > @eslint/eslintrc > js-yaml eslint > minimatch

直接依賴	package.json 類型	執行情境	弱點套件@版本	代表依賴路徑（每個弱點套件列一條最短路徑）
eslint-plugin-tailwindcss	devDependencies	Development-time	nanoid@3.3.11, picomatch@2.3.1, postcss@8.5.6, source-map-js@1.2.1	eslint-plugin-tailwindcss > postcss > nanoid eslint-plugin-tailwindcss > fast-glob > micromatch > picomatch eslint-plugin-tailwindcss > postcss eslint-plugin-tailwindcss > postcss > source-map-js
eslint-plugin-vue	devDependencies	Development-time	lodash@4.17.21, postcss-selector-parser@6.1.2	eslint-plugin-vue > vue-eslint-parser > lodash eslint-plugin-vue > postcss-selector-parser
lint-staged	devDependencies	Development-time	picomatch@2.3.1, yaml@2.8.1	lint-staged > micromatch > picomatch lint-staged > yaml
neostandard	devDependencies	Development-time	brace-expansion@2.0.2, minimatch@9.0.5, picomatch@4.0.3	neostandard > typescript-eslint > @typescript-eslint/typescript-estree > minimatch > brace-expansion neostandard > typescript-eslint > @typescript-eslint/typescript-estree > minimatch neostandard > eslint-plugin-n > ts-declaration-location > picomatch
postcss	devDependencies	Build-time	nanoid@3.3.11, postcss@8.5.6, source-map-js@1.2.1	postcss > nanoid postcss postcss > source-map-js
sass	devDependencies	Build-time	immutable@5.1.3	sass > immutable
sweetalert2	dependencies	Runtime	sweetalert2@11.22.3	sweetalert2
tailwindcss	devDependencies	Build-time	brace-expansion@2.0.2, glob@10.4.5, minimatch@9.0.5, picomatch@2.3.1, postcss-selector-parser@6.1.2, yaml@2.8.1	tailwindcss > sucrase > glob > minimatch > brace-expansion tailwindcss > sucrase > glob tailwindcss > sucrase > glob > minimatch tailwindcss > chokidar > anymatch > picomatch tailwindcss > postcss-nested > postcss-selector-parser tailwindcss > postcss-load-config > yaml
vite	devDependencies	Build-time（dev server 為 Development-time）	esbuild@0.21.5, rollup@4.46.2, vite@5.4.19	vite > esbuild vite > rollup vite
vite-plugin-checker	devDependencies	Development-time	picomatch@4.0.3	vite-plugin-checker > picomatch

直接依賴	package.json 類型	執行情境	弱點套件@版本	代表依賴路徑（每個弱點套件列一條最短路徑）
vue	dependencies	Runtime（弱點套件 postcss / nanoid / source-map-js 屬編譯期，@vue/server-renderer 未使用）	@vue/server-renderer@3.5.18, nanoid@3.3.11, postcss@8.5.6, source-map-js@1.2.1	vue > @vue/server-renderer vue > @vue/compiler-sfc > postcss > nanoid vue > @vue/compiler-sfc > postcss vue > @vue/compiler-sfc > postcss > source-map-js

代表依賴路徑僅供追查依賴來源，並非完整依賴清單；同一弱點套件可能經由多條路徑引入。

3-2 依弱點套件整理（漏洞來源）

從實際存在漏洞的套件出發，查看目前安裝版本、漏洞數量，以及它是透過哪些直接依賴引入。主要用來追查漏洞來源與依賴路徑。

筆數提醒：本表以「弱點套件＋版本」分組，統計角度與 3-1 不同。同一則 Advisory 只會針對單一套件，不會跨套件重複，但可能同時影響同一套件的不同版本，而在多列各算一次：本次 Advisory 1243379 同時影響 postcss-selector-parser 6.0.10 與 6.1.2，所以各列加總為 107 筆，比整體唯一 Advisory 的 106 筆多 1 筆。整體數字以 1-4 的 106 筆為準，3-1、3-2 的分組數量不可直接當成整體漏洞總數。

本節不是列出專案全部安裝的套件，只列「本身有漏洞」的套件，包含兩種：

- 直接安裝、且有漏洞：例如 axios 1.11.0（它是直接依賴，本身也有漏洞）。
- 由其他套件間接引入、且有漏洞：例如 follow-redirects 1.15.11、form-data 4.0.4（由 axios 帶進來），以及 lodash 4.17.21（由 ant-design-vue、eslint-plugin-vue 帶進來）。你沒有直接安裝它們，但它們在依賴樹裡，又被安全公告指出有漏洞，所以也會列在這裡。
- 沒有漏洞的套件不會出現。

弱點套件	目前版本	Advisory 數（A–D）	所屬直接依賴	目標版本（同版本線最低可用）	驗證狀態	備註
@hotwired/turbo	7.3.0	1（C 1）	@hotwired/turbo	8.0.21（跨 Major）	暫緩（C）	7.x 無 版；8 OSV 庫 詢為空 engin 18 符 筆為 C 隨日後 8 升級
@humanfs/node	0.16.6	1（D 1）	eslint	0.16.8	已驗證	
@vue/server-renderer	3.5.18	1（C 1）	vue	3.5.42	超出上層範圍	同版本 可用版 3.5.42 層宣告 3.5.18 直接依 resolu
ajv	6.12.6	1（C 1）	eslint	6.14.0	已驗證	
axios	1.11.0	32（B 3 / C 17 / D 12）	axios	1.20.0	已驗證	
brace-expansion	1.1.12	7（B 7）	eslint	1.1.21	已驗證	

弱點套件	目前版本	Advisory 數（A–D）	所屬直接依賴	目標版本（同版本線最低可用）	驗證狀態	備註
brace-expansion	2.0.2	7（B 7）	neostandard, tailwindcss	2.1.7	已驗證	
browserslist	4.25.2	2（B 1 / C 1）	autoprefixer	4.28.7	已驗證	
esbuild	0.21.5	1（C 1）	vite	0.25.x（隨 vite 6.4.5 的 ^0.25.0）	跨 Major 候選，需整合測試	vite 5 ^0.21. 線無解 6.4.5 esbuil ^0.25 esbuil 0.25.0 OSV 庫 詢為空
flatted	3.3.3	2（C 2）	eslint	3.4.2	已驗證	
follow-redirects	1.15.11	1（C 1）	axios	1.16.2	已驗證	腳本候 1.16.0 仍有 3 （GHS 8r9p- 6h3c GHSA mrwp 3g9p GHSA wrc6- yarn a 有）；i OSV 庫 詢為空 1.16.2
form-data	4.0.4	1（C 1）	axios	4.0.6	已驗證	
glob	10.4.5	2（C 2）	tailwindcss	—	不處理（C）	兩筆皆 10.5.0 那筆， Mode 筆需 1 （跨 M
immutable	5.1.3	3（B 3）	sass	5.1.8	已驗證	
js-yaml	4.1.0	5（C 5）	eslint	4.3.2	已驗證	

弱點套件	目前版本	Advisory 數（A–D）	所屬直接依賴	目標版本（同版本線最低可用）	驗證狀態	備註
lodash	4.17.21	2（C 2）	ant-design-vue, eslint-plugin-vue	4.18.1	已驗證	腳本偵 4.18.0 OSV 仍 GHSA r3pf-4 （修補 4.18.1 4.18.1 版本查
lodash-es	4.17.21	2（C 2）	ant-design-vue	4.18.1	已驗證	同 lod
minimatch	3.1.2	3（B 3）	eslint	3.1.4	已驗證	
minimatch	9.0.5	4（B 4）	neostandard, tailwindcss	9.0.9（部分）	部分修復（Node 18 可裝）	9.0.9 標籤 l v9）依 brace expan ^2.0.2 engin >=16 除 3 筆 （111 11135 11135 9.0.6- 改依賴 brace expan ^5，不 用。G g3hv- m249 （124 Mode 需 mir 11.0.1 賴 bra expan ^5.0.1 Node 上
nanoid	3.3.11	3（D 3）	eslint-plugin-tailwindcss, postcss, vue	3.3.18	已驗證	
picomatch	2.3.1	2（B 2）	eslint-plugin-tailwindcss, lint-staged, tailwindcss	2.3.2	已驗證	
picomatch	4.0.3	2（B 2）	neostandard, vite-plugin-checker	4.0.4	已驗證	

弱點套件	目前版本	Advisory 數（A–D）	所屬直接依賴	目標版本（同版本線最低可用）	驗證狀態	備註
postcss	8.5.6	4（B 3 / D 1）	eslint-plugin-tailwindcss, postcss, vue	8.5.23	已驗證	
postcss-selector-parser	6.0.10	1（B 1）	@tailwindcss/typography	6.1.5	超出上層範圍	同版本可用版 6.1.5 超層宣告 6.0.10 直接依 resolu
postcss-selector-parser	6.1.2	2（B 2）	eslint-plugin-vue, tailwindcss	6.1.5	已驗證	
rollup	4.46.2	1（B 1）	vite	4.59.0	已驗證	
source-map-js	1.2.1	1（D 1）	eslint-plugin-tailwindcss, postcss, vue	1.2.2	已驗證	
sweetalert2	11.22.3	1（D 1）	sweetalert2	11.22.4	已驗證	
vite	5.4.19	11（B 1 / C 2 / D 8）	vite	6.4.5	跨 Major 候選，需整合測試	5.x 最 5.4.21 仍有 8 同線無 6.4.4 有 GH 8g5g-grgj，版本查空；engin ^18 符
yaml	2.8.1	1（C 1）	lint-staged, tailwindcss	2.8.3	已驗證	

驗證狀態說明：「已驗證」＝yarn audit 的受影響範圍、semver 最低版本計算、OSV 版本查詢三者一致，且 registry 的 `engines.node` 已查。腳本本身的 `verified` 恆為 False，「已驗證」由本報告在 OSV 核對後標註。

3-3 重點案例

案例 1：axios 原型污染 gadget（D）

- Advisory：
  - 1117593｜high｜GHSA-6chq-wfr3-2hj9｜CVE-2026-42035｜https://github.com/advisories/GHSA-6chq-wfr3-2hj9｜本筆分類 D
  - 1120650｜high｜GHSA-35jp-ww65-95wh｜CVE-2026-44494｜https://github.com/advisories/GHSA-35jp-ww65-95wh｜本筆分類 C
- Severity：High
- 弱點套件：axios
- 版本：axios 1.11.0 → 建議 1.20.0（已驗證）
- 依賴來源：axios

1. 漏洞簡介

axios 在組合請求設定時，會讀到「從 `Object.prototype` 繼承來的值」。

只要程式別處先被污染了原型（例如某個套件對外部輸入做不安全的合併），攻擊者就能藉由 axios 偷改 header、代理或回應。axios 本身不會製造污染，是被別處污染後才會中招。

2. 攻擊成立條件

- 程式其他地方必須先存在原型污染來源。
- 攻擊者必須能控制觸發污染的輸入。
- axios 必須執行受影響的程式路徑（設定合併，每次請求都會走到）。

3. 本專案使用情況

- `myAxios.js` 每次請求都會走到設定合併，程式路徑可達。
- `app/packs` 內沒有對外部輸入做深層合併（`JSON.parse` 只建立自有屬性，不會污染原型）。
- 第三方套件是否有污染來源，尚未確認。
- 其中 1120650（`config.proxy`）只在 Node http adapter 生效，已獨立歸為 C。

4. 分類結果與判斷理由

- 分類：D（需要更多資訊）
- 判斷理由：程式路徑可達，但「別處已有污染來源」這個前提無法確認，故為 D 而不是 C。

5. 建議後續動作

- 檢查第三方套件（i18n-js 的 `merge` 、tablesorter、jQuery 外掛）處理外部輸入的路徑。
- 同時將 axios 更新至 1.20.0 消除（建議）。

案例 2：axios Node 專屬路徑（C）

- Advisory：
  - 1112195 | high | GHSA-4hjh-wcwx-xvwj | CVE-2025-58754 | https://github.com/advisories/GHSA-4hjh-wcwx-xvwj
  - 1117587 | moderate | GHSA-5c9x-8gcm-mpgx | CVE-2026-42034 | https://github.com/advisories/GHSA-5c9x-8gcm-mpgx
- Severity：High / Moderate
- 弱點套件：axios
- 版本：axios 1.11.0 → 建議 1.20.0（已驗證）
- 依賴來源：axios

1. 漏洞簡介

這兩筆發生在 Node.js 的 http adapter（處理 `data:` 網址、串流上傳）。

瀏覽器裡 axios 走 XHR adapter，不會執行這段程式。

2. 攻擊成立條件

- axios 必須跑在 Node.js 端，並走 http adapter。

3. 本專案使用情況

- axios `package.json` 的 `browser` 欄位把 `lib/adapters/http.js` 與 Node 版 `FormData` 指向 null。
- `myAxios.js` 只有 `axios.create({})` ，沒有 adapter、proxy、maxRedirects。
- 本機打包產物 `public/vite/assets` （25 個 js，檔案日期 2026/06/29）搜尋不到 `follow-redirects` 、 `maxRedirects` 、 `NO_PROXY` 。
- 限制：打包產物日期早於本次檢核，需要重新 build 後再確認一次（需進一步確認）。

4. 分類結果與判斷理由

- 分類：C（目前影響有限）
- 判斷理由：有正面證據（browser 欄位、打包產物）顯示 Node 路徑不會在瀏覽器執行，故為 C。

5. 建議後續動作

- 隨 axios 1.20.0 更新消除，無需單獨處理。
- 重新 build 後再搜尋一次打包產物。

案例 3：brace-expansion 遞迴與記憶體 DoS（B）

- Advisory：
  - 1240104 | high | GHSA-qhr7-859c-m2p7 | CVE-2026-102278 | https://github.com/advisories/GHSA-qhr7-859c-m2p7
  - 1130736 | high | GHSA-rgw5-rvv9-x895 | CVE-2026-69152 | https://github.com/advisories/GHSA-rgw5-rvv9-x895
- Severity：High
- 弱點套件：brace-expansion

- 版本：brace-expansion 1.1.12 → 建議 1.1.21（已驗證）；2.x 線為 2.1.7
- 依賴來源：eslint > @eslint/config-array > minimatch > brace-expansion

1. 漏洞簡介

特殊格式的大括號字串（例如 `{a,{b,{c…` ）會讓套件遞迴過深或配置大量記憶體，導致程式無法回應（DoS）。

2. 攻擊成立條件

- 攻擊者能控制被比對的 pattern 字串。
- 該套件在執行環境中處理該 pattern。

3. 本專案使用情況

- 透過 eslint、neostandard、tailwindcss 的檔案 pattern 比對引入（路徑為 1.x 線；2.x 線經 neostandard、tailwindcss）。
- 只在 lint 與建置時執行，pattern 來自設定檔與 repo，不是外部輸入。
- 1.x 與 2.x 兩條版本線各有 7 筆，目標分別為 1.1.21、2.1.7，在上層範圍內。

4. 分類結果與判斷理由

- 分類：B（建議修復）
- 判斷理由：工具鏈必定執行、程式碼可達，且有現成修補版；輸入來自 repo 設定而非外部，故為 B 而不是 A。

5. 建議後續動作

- 以 `yarn upgrade` 更新鎖檔內的 brace-expansion（見 2-2 順位 4）。

案例 4：postcss 讀取任意檔案（B）

- Advisory：
  - 1124252 | high | GHSA-6g55-p6wh-862q | CVE-2026-45623 | https://github.com/advisories/GHSA-6g55-p6wh-862q
  - 1139510 | high | GHSA-r28c-9q8g-f849 | CVE-2026-73646 | https://github.com/advisories/GHSA-r28c-9q8g-f849
- Severity：High
- 弱點套件：postcss
- 版本：postcss 8.5.6 → 建議 8.5.23（已驗證）
- 依賴來源：eslint-plugin-tailwindcss > postcss

1. 漏洞簡介

CSS 檔案最後一行可以寫 `/*# sourceMappingURL=... */` ，postcss 會去讀那個路徑。

若 CSS 內容被惡意構造，可能讀到不該讀的檔案。

2. 攻擊成立條件

- 攻擊者能讓惡意 CSS 進入建置流程。
- postcss 處理該 CSS 並解析 sourceMappingURL。

3. 本專案使用情況

- 建置時會處理專案 CSS 與相依套件的 CSS，輸入來自 repo 與相依套件，不是外部使用者輸入。
- 若 CI 接受外部 PR，惡意 CSS 才可能進來；repo 可見性與 fork 權限未確認（需進一步確認）。

4. 分類結果與判斷理由

- 分類：B（建議修復）
- 判斷理由：建置時必定執行、程式碼可達，且有現成修補版；輸入來自 repo 與相依套件而非外部使用者，故為 B 而不是 A。

5. 建議後續動作

- 更新 postcss 至 8.5.23（見 2-2 順位 3）。
- 確認 CI 是否接受外部 PR。

案例 5：vite 開發伺服器（B / C / D）

- Advisory：
  - 1107327 | low | GHSA-jqfw-vq24-v9c3 | CVE-2025-58752 | https://github.com/advisories/GHSA-jqfw-vq24-v9c3 | 本筆分類 B
  - 1107323 | low | GHSA-g4jq-h2w9-997c | CVE-2025-58751 | https://github.com/advisories/GHSA-g4jq-h2w9-997c | 本筆分類 C
- Severity：Low（同套件另有 High / Moderate）
- 弱點套件：vite

- 版本：vite 5.4.19 → 建議 6.4.5（跨 Major 候選，需整合測試）
- 依賴來源：vite

1. 漏洞簡介

這些是 vite 開發伺服器（ `bin/vite dev` ）的檔案存取限制被繞過，讓不該被讀到的檔案被讀走。

只在開發機啟動 dev server 時才有。

2. 攻擊成立條件

- dev server 對外（區網）開放。
- 各筆另有前提：public 內有 symlink、appType 為 custom / middlewareMode、Windows、.map 檔含敏感內容等。

3. 本專案使用情況

- `Procfile.dev` 啟動 `bin/vite dev` ， `config/vite.json` 設定 host 0.0.0.0、port 3056，對整個區網開放，屬於可達，但只影響開發機，不影響正式環境。
- 1107327 符合前提（對外開放、appType 預設 spa）。
- 1107323 需要 public 內有 symlink（ `find public -type l` 為 0 筆）；1242724 需要 appType custom / middlewareMode（專案未設定）。
- 1116229 需要 .map 檔含敏感內容且路徑可預測，尚未檢查；Windows 或 launch-editor 相關 6 筆與 1242730（import 路徑前提未檢查）也尚未確認。

4. 分類結果與判斷理由

- 分類：B 1 筆（1107327） / C 2 筆（1107323、1242724） / D 8 筆
- 判斷理由：依公告前提逐筆核對：前提符合者為 B、前提不成立者為 C、前提尚未確認者為 D。

5. 建議後續動作

- 詢問團隊開發機是否有 Windows、是否使用開啟編輯器功能。
- 檢查 .map 檔內容與 import 路徑。
- 評估升 vite 6.4.5（見 2-2 順位 5）。

案例 6：lodash / lodash-es 程式碼注入與原型污染（C）

- Advisory：
  - 1115806 | high | GHSA-r5fr-rjxr-66jc | CVE-2026-4800 | https://github.com/advisories/GHSA-r5fr-rjxr-66jc
  - 1244531 | moderate | GHSA-xxjr-mmjv-4gpg | CVE-2025-13465 | https://github.com/advisories/GHSA-xxjr-mmjv-4gpg
- Severity：High / Moderate
- 弱點套件：lodash、lodash-es
- 版本：lodash 4.17.21 → 建議 4.18.1（已驗證）
- 依賴來源：eslint-plugin-vue > vue-eslint-parser > lodash

1. 漏洞簡介

`_.template` 的 imports 鍵名可注入程式碼。

`_.unset` 、 `_.omit` 、 `_.pullAt` 的陣列路徑可繞過檢查造成原型污染。

2. 攻擊成立條件

- 程式呼叫上述弱點函式。
- 傳入的鍵名或路徑可被攻擊者控制。

3. 本專案使用情況

- 使用者是 ant-design-vue、i18n-js、vue-eslint-parser，以及 @vue/compiler-sfc（consolidate 前處理器），已逐一搜尋它們的原始碼。
- 只有 ant-design-vue 的 `form/useForm.js` 呼叫 `omit` ，鍵固定為 `wait` ，且專案沒有使用 `Form.useForm` 或 `a-form` 。
- 其餘只呼叫 `isEmpty` 、 `get` 、 `has` 、 `merge` 等不相關函式。
- `@vue/compiler-sfc` 的 consolidate 路徑（ `compiler-sfc.cjs.js:3296-3304` ）會呼叫 `template` ，但只在 `<template lang=...>` 前處理器時觸發； `app` 內的 .vue 沒有 template lang，也沒有 `preprocessLang` 。
- 搜尋範圍： `node_modules/ant-design-vue/{es,lib}` 、 `node_modules/i18n-js/dist` 、 `node_modules/vue-eslint-parser/index.js` 、 `node_modules/@vue/compiler-sfc/dist` 、 `app/packs` 。

4. 分類結果與判斷理由

- 分類：C（目前影響有限）

- 判斷理由：搜尋範圍內的證據齊備，確認弱點函式不會被觸發，故為 C。

5. 建議後續動作

- 可順帶升到 4.18.1。
- 專案開始使用 `Form.useForm / a-form` 時重評。

四、專案影響分析

本章不是再列一次漏洞，而是說明為什麼這些漏洞在本專案會被判斷為 A、B、C、D。個別漏洞的敘述與分類結果在 3-3，本章只整理跨案例共用的證據，各節回答的問題如下：

- 4-1 依賴類型：這個套件在哪個執行情境中使用？
- 4-2 實際使用位置：專案實際在哪些程式碼使用相關功能？
- 4-3 Reachability：弱點程式碼是否有執行路徑？
- 4-4 輸入來源：攻擊者能否控制進入弱點程式碼的資料？
- 4-5 已確認事實、推論、尚未確認：哪些已經確認，哪些還需要團隊補查？

4-1 依賴類型與執行情境

Reachability 的定義見 1-2。

`package.json` 類型與實際執行情境分開記錄。專案沒有 `peerDependencies` ，也沒有 `resolutions` 。

執行情境	直接依賴	說明
Runtime（正式環境的瀏覽器）	axios、@hotwired/turbo、ant-design-vue、sweetalert2、vue	打包進使用者瀏覽器；專案沒有 SSR
Build-time	vite、postcss、tailwindcss、sass、autoprefixer、@tailwindcss/typography	`vite build` 與 CSS 處理；輸出會進入部署產物，但弱點程式本身只在建置機執行
Development-time	eslint、eslint-plugin-vue、eslint-plugin-tailwindcss、neostandard、lint-staged、vite-plugin-checker；vite dev server	lint、pre-commit、CI lint、開發機 dev server

CI 暴露面： `frontend-lint.yml` 在 `pull_request` （路徑含 `**/*.js` 、 `**/*.vue` 、 `.nvmrc` ）與 push 到 master 時執行 `yarn install` （鎖檔快取未命中時才跑）與 `yarn lint:check` （repo 預設分支為 main、 `master` 分支不存在，push 觸發實際不會啟動，只剩 `pull_request` ），所以 lint 工具鏈會在 CI 上處理 PR 內容。是否有外部 PR 需進一步確認。 `pre-commit` 以 `yarn lint-staged` 執行 prettier 與 eslint。

4-2 實際使用位置

弱點來源	專案實際使用位置
axios	前端網路請求只經 `myAxios.js` （ `axios.create({})` ），共 5 處呼叫：LoginPage、UserForm、PermissionForm、UserSettingModal、ImportForm；皆為相對路徑、 `method` / `url` / `data` / `headers` 的物件常值
@hotwired/turbo	只使用 Turbo Drive，沒有 `<turbo-frame>`
vue（SSR 相關）	沒有 SSR，沒有使用 `renderToString` 、 `createSSRApp`
lodash、lodash-es	由 ant-design-vue、i18n-js、vue-eslint-parser、@vue/compiler-sfc 使用；專案沒有使用 `Form.useForm / a-form` （見案例 6）
vite dev server	`Procfile.dev` 以 `bin/vite dev` 啟動， `config/vite.json` 設定 host 0.0.0.0、port 3056
eslint、postcss、lint-staged 等工具鏈	pre-commit 執行 `yarn lint-staged` ，CI 執行 `yarn lint:check` ；沒有 YAML 設定輸入、沒有 `--cache` 、沒有 browserslist 設定

4-3 Reachability

群組	Reachability	證據（細節見案例或附錄 B）
axios Node / fetch 專屬（17 筆）	Unreachable	瀏覽器走 XHR adapter，不執行 Node http adapter（見案例 2）
axios 原型污染 gadget（12 筆）	Reachable，前提未確認	設定合併每次請求都會執行（見案例 1）
axios 可達但輸入受控（3 筆）	Reachable	ImportForm 的 multipart、XSRF cookie 預設名稱；設定為物件常值
follow-redirects、form-data	Unreachable	僅 axios Node adapter 使用（見案例 2）
lodash、lodash-es	Unreachable	弱點函式未被呼叫（見案例 6）
@hotwired/turbo	Unreachable	沒有 `turbo-frame`（見 4-2）
@vue/server-renderer	Unreachable	專案不使用 SSR（見 4-2）
esbuild、glob、ajv、js-yaml、yaml、flatted、browserslist（stats）	Unreachable	見附錄 B 的逐筆依據
工具鏈 B 群（brace-expansion、minimatch、picomatch、postcss、postcss-selector-parser、rollup、immutable、browserslist）	Reachable	lint / 建置時必定執行（見案例 3、4）
vite dev server	Reachable（B 1 筆） / Unreachable（C 2 筆） / Unknown 或前提未確認（D 8 筆）	依公告前提逐筆判定（見案例 5）

4-4 輸入來源

執行情境	進入弱點程式碼的資料	攻擊者能否控制
Runtime（瀏覽器）	axios 請求設定（程式內的物件常值）；伺服器提供的 dataset（以 `JSON.parse` 解析，不會污染原型）	目前未見可控入口；第三方套件是否有原型污染來源尚未確認（見 4-5）
Build-time	repo 內的 CSS、scss 與設定檔	只有 repo 內容；CI 若接受外部 PR，惡意內容才可能進來（是否接受見 4-5）
Development-time	lint pattern、設定檔；dev server 對區網開放	區網內的人可連到 dev server（見案例 5）；lint 輸入同 Build-time

4-5 已確認事實、推論、尚未確認

類型	內容
已確認事實	4-2 所列的使用位置，以及「專案沒有使用」的項目（SSR、Form.useForm、turbo-frame、YAML 設定輸入、 `--cache` 、browserslist 設定）
已確認事實	axios 在瀏覽器的 browser 欄位排除 Node http adapter 與 Node FormData
推論	正式環境風險主要集中在「原型污染 gadget」這一類，且需要別處先有污染來源
推論	本機 `public/vite/assets` 的結果代表目前 lock 的建置結果，但檔案日期為 2026/06/29，可能與現況不同
尚未確認	第三方套件是否存在可由外部輸入觸發的原型污染來源（axios 的 12 筆 D）
尚未確認	團隊開發機是否有 Windows（vite 的 6 筆 D）；CI 是否接受外部 PR；部署網域的 TLD（sweetalert2 的觸發條件）

五、更新相容性與驗證

5-1 Node.js 版本相容性

重點結論

1. 本次有 1 筆 B 類 Advisory（1244623，minimatch 9.x 線）無法在 Node 18 環境下完全修復：它需要 minimatch 11.0.1，其依賴 brace-expansion ^5.0.12 要求 Node 20 以上。
2. 另有 1 筆 C 類（1244013，glob）受相同限制（glob 14.0.2 依賴 minimatch ^11）。
3. 其餘建議更新的目標版本，均符合目前 Node 18 的環境需求。
4. 本次建議的 vite 6.4.5 支援 Node 18，不需要為這次更新升級 Node。

是否需要調整專案 Node 版本：本次不需要。只有要消除上述 2 筆時，才需要把專案 Node 提高到 20 以上，是否值得由工程師決定。

專案 Node.js 設定

- `.nvmrc` =18、`package.json` 的 `engines.node` = `>=18 <20`（專案自設上限）、`frontend-lint.yml` 讀 `.nvmrc`；專案 `CLAUDE.md` 沒有 Node 版本設定。
- 本機 nvm 為 v18.20.8。
- 修補版 `engines.node` 以 npm registry 為準（唯讀查詢）。

補充說明

- minimatch 9.x 的其餘 3 筆 High 可用 9.0.9（npm 標籤 `legacy-v9`，依賴 brace-expansion ^2.0.2，Node 18 可裝）消除；9.0.6–9.0.8 改依賴 brace-expansion 5.x，不應選用。
- 這是專案 `engines.node` 上限 `<20` 造成的限制，不是套件本身不相容。
- 一層傳遞依賴只做粗略檢查（以 npm registry 的 `dependencies` 與 `engines.node` 比對），未發現其他不相容，不是完整解析。
- `@humanfs/node` 0.16.8 要求 `>=18.18.0`，專案 `engines` 的 `>=18` 允許 18.0–18.17；CI 的 `.nvmrc` 解析結果需進一步確認。
- yarn 實際安裝需在 Node 18 以更新後的 lock 實測（需進一步確認）。

未來版本限制

- Vite 7 要求 Node 20.19 以上。
- 專案目前設定 `engines.node` `>=18 <20`，因此未來升級 Vite 7 前，需要先調整專案 Node 版本設定。
- 本次建議的 Vite 6.4.5 支援 Node 18，不受影響。

完整的目標版 `engines.node` 與新增傳遞依賴檢查資料，見附錄 A（表 A-1、表 A-2）。

5-2 更新驗證

分兩個階段，兩者的結果不可混用：

階段	驗證內容	結果性質
更新前 / 預測	提供更新後的 yarn.lock，預測弱點是否消除	預測，不是實際掃描結果
更新後 / 實測	重跑 audit、lint、build、E2E，確認沒有引入新問題	實測，新漏洞以此為準

階段一：更新前 / 預測

- [ ] 提供更新後的 `yarn.lock`，用 `parse_audit.py --after-lock` 預測弱點是否消除（報告中標示為預測）
- 預測只依 lockfile 的版本推算，不代表實際掃描結果，也看不出新引入的漏洞。

階段二：更新後 / 實測

- [ ] 重跑 `yarn audit --json`，用 `--after-audit` 實測（新漏洞以實測為準）
- [ ] 確認沒有新增依賴衝突
- [ ] `yarn lint:check`：確認程式碼檢查正常
- [ ] `vite build`：確認前端建置正常；重新 build 後再搜尋打包產物，確認 axios Node 路徑仍不在 bundle 內（本報告使用的是 2026/06/29 的產物）
- [ ] E2E：確認登入、表單、上傳等主要流程